

Dual-Certificate Architecture for Secure IoT-to-Blockchain RWA Tokenization

Aygun Salimova
Dept. of Computer Engineering
Ajou University
Suwon, Republic of Korea
aygunsalimovaa@ajou.ac.kr

Ki-Hyung Kim*
Dept. of Cyber Security
Ajou University
Suwon, Republic of Korea
kkim86@ajou.ac.kr

Abstract—Real-world asset (RWA) tokenization represents physical assets as blockchain tokens whose valuation must track Internet-of-Things (IoT) sensor data. Existing approaches treat the edge gateway that aggregates this data as an implicitly trusted boundary and do not separate two distinct questions: whether the gateway can be trusted, and whether it is permitted to report for a particular asset. We design a dual-certificate architecture that makes this separation explicit. An Edge Attestation Certificate (EAC) certifies gateway device identity and execution integrity; a Gateway Authorization Certificate (GAC) certifies the gateway's right to represent a specific asset. Oracles verify both certificates atomically before any on-chain update. The architecture bridges the Matter protocol's device attestation with TPM-based edge attestation, enabling vendor-independent deployment on commodity hardware. We implement a prototype on TPM 2.0 hardware and a Solidity smart contract and evaluate it across attack prevention (including a single-certificate ablation), verification latency, and blockchain cost. The prototype rejects both attack classes in 100% of trials at 0.025 ms mean oracle verification latency and a constant 92,061 gas independent of sensor count.

Index Terms—Real-World Asset Tokenization, IoT Security, Edge Attestation, Blockchain Oracles, Smart Contracts, Matter Protocol, TPM.

I. INTRODUCTION

Real-world asset (RWA) tokenization represents a physical asset—a building, a vehicle, an energy installation—as a blockchain token, enabling fractional ownership and automated settlement [1]. Unlike a purely digital asset, an RWA derives its value from the physical world, so its token valuation must track continuous real-world signals—occupancy, energy consumption, environmental conditions—supplied by IoT sensors to a smart contract.

Consider a tokenized commercial building whose token price is computed from on-chain occupancy and energy metrics. Blockchain immutability alone is not enough for an investor: immutability guarantees that a recorded value cannot later be altered, but it says nothing about whether the value was correct at the moment it was written. An investor therefore needs assurance of three further things: (i) the readings came from genuine sensors, (ii) the gateway that aggregated those readings was running approved, unmodified software, and (iii) that gateway was authorized to report for this particular building rather than some other one. A single rogue or

misauthorized gateway is thus not a data-quality nuisance but a financial-fraud vector.

We use three terms throughout. An *oracle* is the off-chain service that delivers external data to a smart contract; because the blockchain cannot itself observe the physical world, the oracle is the point at which off-chain trust must be established. *Attestation* is a hardware-signed proof, produced by a security chip such as a TPM, that reports the exact software state of a device. *Gateway execution integrity* is the property—established through attestation—that the edge gateway is running the specific approved software image and has not been tampered with: the gateway is where raw sensor readings are aggregated and filtered, so if its code can be silently replaced, every downstream on-chain value inherits that compromise.

Existing approaches assume trusted data sources without standardized verification, rely on proprietary IoT stacks that limit interoperability, and use oracle mechanisms that validate consensus among providers rather than provenance of the data [2]. Most critically, no existing work separates gateway device trust from asset-authorization trust. This gap enables two concrete attacks.

Attack 1: Unauthorized Gateway Deployment. An adversary deploys a rogue gateway that claims to report a building's data. Without device-level attestation, oracles cannot tell a legitimate gateway from a malicious one.

Attack 2: Asset Authorization Violation. A legitimate operator with a technically sound, attested gateway in Building B submits Building B's genuine data while claiming it represents Building A, a higher-value property. The gateway has valid technical credentials but no authorization for the claimed asset. Single-certificate designs cannot prevent Attack 2 because they conflate device authenticity with asset authorization.

Contributions. (1) We separate device attestation and execution integrity (EAC) from asset authorization (GAC), and show this separation is necessary to prevent both attacks. (2) We bridge the Matter protocol's device-attestation layer [3] with blockchain oracles, extending cryptographic trust from 280+ certified sensor types through TPM-attested edge gateways to on-chain settlement. (3) We design an Edge Attestation Authority (EAA) that verifies TPM-based gateway integrity and issues the two certificates. (4) We implement and evaluate a prototype on TPM 2.0 hardware and a Solidity smart

contract, including a single-certificate ablation that isolates the role of the GAC. The prototype blocks both attack classes in 100% of trials at 0.025 ms mean verification latency and $O(1)$ gas cost.

II. RELATED WORK

RWA tokenization enables fractional ownership but relies on trusted off-chain data [1]. Existing work focuses on smart-contract design and regulatory frameworks while treating sensor data as externally provided without provenance verification. Prior work shows blockchain efficiency for real-estate settlement but assumes trusted gateways [4]. Evaluation across these strands is largely architectural or simulation-based; we instead evaluate a hardware prototype with TPM-backed signing and end-to-end on-chain measurements.

IoT-Blockchain Integration. Several frameworks integrate IoT devices with blockchain. Dorri et al. [5] propose a blockchain-based smart-home architecture using a local miner as a trusted gateway, but rely on a single device identity without separating authorization rights from device credentials. Novo [6] addresses scalable access management for IoT on blockchain but does not address edge gateway attestation or the problem of a legitimate device submitting data for an unauthorized asset. These works treat the gateway as a trusted boundary rather than an entity requiring independent attestation.

Oracle Networks and Security. Oracle networks aggregate off-chain data through multi-provider consensus [2]. Chainlink 2.0 achieves Byzantine fault tolerance through a supermajority of independent nodes, but validates agreement among providers rather than cryptographic provenance of an individual source. Zhang et al. [7] introduce Town Crier, an authenticated data feed using Intel SGX, establishing that hardware-backed attestation can replace consensus-based trust. However, Town Crier attests to the execution environment of the oracle node itself, not to the field gateway that originates sensor data, leaving the gateway-to-oracle boundary unaddressed. Oracle manipulation through compromised data sources remains an active attack vector [8].

Trusted Execution Environments. TEE-based approaches using Intel SGX or ARM TrustZone provide execution integrity through hardware-enforced isolation [9]. TEEs attest that code runs unmodified within a secure enclave—analogueous to our EAC execution-integrity property—but deploying SGX on constrained IoT edge gateways is impractical due to hardware and power requirements. TPM 2.0, by contrast, is present in a wide range of embedded and IoT gateway hardware and enables remote attestation without full TEE support [10].

Matter Protocol. Matter [3] is an IP-based IoT standard providing Device Attestation Certificates (DAC) for hardware authentication. Each device receives a DAC during manufacturing, establishing provenance through certificate chains. With 280+ certified devices across vendors, Matter provides standardized authentication that avoids proprietary lock-in. However, Matter's DAC applies only to sensors within local fabrics; edge gateways that aggregate data across fabrics and

TABLE I
SECURITY PROPERTY COMPARISON

Security Property	Single-Cert	Chainlink [2]	Town Crier [7]	This Work
Device authenticity	✓	×	×	✓ (EAC)
Execution integrity	×	×	✓ (SGX)	✓ (EAC+TPM)
Asset authorization	×	×	×	✓ (GAC)
Attack 1 prevention	✓	×	×	✓
Attack 2 prevention	×	×	×	✓
IoT hardware compatible	✓	N/A	×	✓ (TPM 2.0)
Vendor-independent	varies	N/A	×	✓ (Matter)

interface with blockchain oracles operate outside Matter's trust model.

Research Gap. No existing work separates gateway execution integrity from asset authorization. Prior systems assume trusted gateways, provide device attestation without authorization constraints, or validate oracle consensus without provenance [11]. Our dual-certificate architecture treats execution integrity (EAC) and asset authorization (GAC) as independent security properties verified atomically by oracles. Table I shows that single-certificate systems prevent Attack 1 but not Attack 2, because device authenticity does not imply asset authorization. Chainlink's consensus model gives no gateway-level provenance. Town Crier provides execution integrity through SGX but requires TEE hardware unavailable on constrained gateways and does not bind asset authorization. Only the dual-certificate model provides all three properties on commodity TPM-equipped hardware.

III. DUAL-CERTIFICATE ARCHITECTURE

A. System Overview

Three layers carry physical-world data from sensors to a smart contract (Fig. 1). Data flows in one direction—upward—and trust is added at each layer.

Matter IoT Layer. Certified sensors are commissioned into Matter fabrics using DAC-based authentication. A Matter controller verifies each device's certificate chain and issues a Node Operational Certificate (NOC) granting fabric membership. Devices communicate over encrypted sessions. This layer establishes device-level trust.

Edge Trust Layer. A TPM-enabled gateway subscribes to Matter attribute reports, aggregates them locally, and runs anomaly detection. The Edge Attestation Authority (EAA)—the trusted authority that verifies gateway attestation and issues certificates, playing the role a Certificate Authority plays in web PKI—verifies the gateway's integrity and issues two distinct certificates: an EAC for device authentication and execution integrity, and a GAC for asset-representation rights. This layer adds execution-integrity and asset-authorization trust.

Oracle and Blockchain Layer. Decentralized oracle nodes verify the EAC and GAC against on-chain registries and reach Byzantine fault-tolerant consensus (a 5-of-7 supermajority)

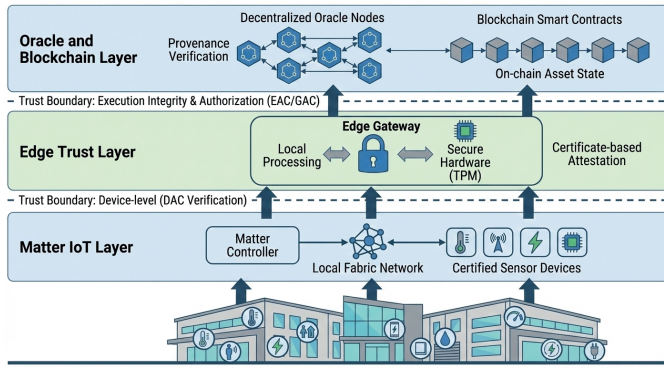


Fig. 1. System architecture. Three layers carry data upward: the Matter IoT layer establishes device identity, the Edge Trust layer adds execution-integrity (EAC) and asset-authorization (GAC) proofs, and the Oracle/Blockchain layer verifies both before writing on-chain. Trust boundaries are explicit and crossed only after verification.

before submitting an update to the smart contract. This layer enforces certificate-based provenance.

In short, a sensor reports a value; the gateway aggregates it and signs the result with its TPM-held key; the oracle checks the EAC (is this a registered, untampered gateway?) and the GAC (is it allowed to speak for the claimed asset?); only if both checks pass does the value reach the contract.

B. Edge Attestation Certificate (EAC)

The EAC provides device authentication and execution-integrity verification for an edge gateway.

Device authentication. During enrollment, the gateway operator registers the gateway's TPM endorsement key—a unique key burned into the TPM at manufacture that anchors the device's hardware identity—with the EAA, which maintains a registry of authorized devices. An unregistered device cannot obtain a valid EAC, which is what prevents Attack 1.

Execution integrity. EAC issuance follows standard TCG TPM-based remote attestation [10]. The gateway sends the EAA a TPM quote—a signed report of its software measurements with a nonce to prevent replay. The EAA verifies the device identity through the endorsement-key credential [12] and checks that the measured software matches the approved image. On success the EAA issues an EAC containing the gateway's TPM-derived public key, a 90-day validity period, and the EAA signature. EACs are renewed by periodic re-attestation, so a gateway that is later tampered with fails its next attestation and cannot renew.

C. Gateway Authorization Certificate (GAC)

The GAC establishes that a specific gateway is authorized to represent a specific asset. Where the EAC answers “is this gateway technically trustworthy?”, the GAC answers “is it administratively permitted to speak for this asset?”.

Issuance. The asset owner requests a GAC from the EAA, supplying proof of asset ownership and the gateway identifier (the public key from the EAC). The EAA verifies the ownership credentials and issues a GAC that cryptographically binds

the gateway to the asset's unique identifier. The GAC contains the gateway's public key (identical to the EAC's), the asset identifier (a blockchain address), a 180-day validity period, and the EAA signature. Because both certificates carry the same public key, an oracle can verify that the entity presenting them is the one that signed the data.

Lifecycle. The GAC's validity is longer than the EAC's (180 vs. 90 days) because asset authorization changes less often than device state. A GAC can be revoked immediately through an on-chain transaction if ownership transfers or a security incident occurs. This separation is what prevents Attack 2: a gateway with a valid EAC for Building B cannot submit data claiming Building A without a corresponding GAC.

D. Oracle Verification Protocol

On receiving a signed submission, an oracle performs atomic verification of both certificates. It retrieves the EAC and GAC from the on-chain registry, verifies the EAA signatures on both, checks validity periods and revocation status, confirms that the asset identifier in the GAC matches the submission's claimed asset, and finally validates the data-payload signature against the gateway's public key.

All-or-nothing. Data is accepted only if both certificates are present, currently valid, correctly signed, share the same public key, and the GAC's asset identifier matches the claimed asset. Any missing or invalid element causes immediate rejection. This atomic check ensures device trust, execution trust, and asset authorization are evaluated together rather than independently, and it runs well under the 100 ms oracle budget through efficient signature operations and local certificate caching.

IV. SECURITY ANALYSIS

Attack 1 — Unauthorized Gateway Deployment (EAC defense). During attestation the EAA checks whether the gateway's TPM endorsement key matches a registered device. An unknown TPM is not registered, so EAC issuance fails. When the rogue gateway later attempts a submission, oracles reject it immediately because no valid EAC exists.

Attack 2 — Asset Authorization Violation (GAC defense). A legitimate operator enrolls a real gateway in Building B. It passes TPM verification, receives a valid EAC, and collects genuine data. The adversary then submits Building B's data while claiming it represents Building A. Both the honest and the dishonest submissions present a valid EAC, so device authenticity and execution integrity cannot distinguish them. The GAC does: the Building B gateway holds a GAC issued only for Building B. When oracles compare the claimed asset identifier against the GAC, the mismatch is detected and the submission is rejected.

Why single-certificate systems fail. With only the EAC, a technically sound gateway could report for any asset because nothing binds it to one; single-certificate designs conflate technical trust with administrative authorization. Section V isolates this with an ablation.

Assumptions and threat model. We assume the EAA issues certificates only after correct verification—the standard web-PKI assumption—and that TPM 2.0 attestation is sound [10],

[12]. The first is bounded by an on-chain registry of all issued certificates and on-chain revocation, making misissuance auditable; a decentralized EAA using threshold signing removes the single point of trust entirely, and our certificate format is signer-agnostic to allow this substitution without protocol change. The second is a residual physical-attack risk: extracting a TPM endorsement key requires hardware-invasive attacks on the specific chip, which a remote adversary cannot perform. Within these assumptions our adversary may deploy malicious devices, compromise sensors, operate rogue gateways, and observe network traffic; forging either certificate requires the EAA's signing key and impersonating a registered gateway requires its TPM-bound key, neither of which the adversary holds.

V. IMPLEMENTATION AND EXPERIMENTAL RESULTS

A. Experimental Setup

Hardware and software. The EAA runs on an evaluation server (Intel Core) using the Python `cryptography` library for RSA-PKCS1v15 key management and GAC issuance. The gateway runs on a Raspberry Pi equipped with a TPM 2.0 chip, which performs hardware-backed EAC signing via `tpm2_sign` at persistent handle `0x81010001`. The blockchain layer is a local Hardhat node (Solidity 0.8.28, EVM chain ID 31337) running the `RWADataVault` smart contract; gas is measured on the contract's `updateAsset()` call.

Dataset. As a surrogate for the Matter sensor layer we use a 500-row Kaggle Smart Home Energy Usage CSV [13] spanning 34 unique asset identifiers. Each row is a real smart-home reading with energy-consumption, temperature, humidity, and occupancy fields—matching the building-monitoring metrics a production RWA deployment would ingest. The gateway's GAC authorizes 5 of the 34 identifiers (H088, H060, H063, H055, H012); all 33 matching rows were submitted without error.

Measurement protocol. Oracle verification is benchmarked over 500 iterations after a 10-iteration warmup. Each iteration performs RSA-PKCS1v15/SHA-256 signature verification of the GAC followed by an asset-identifier lookup—exactly the logic an oracle executes. We evaluate four dimensions: (i) attack prevention with a single-certificate ablation; (ii) oracle verification latency; (iii) blockchain cost vs. sensor density; and (iv) end-to-end pipeline latency. Headline values are summarized in Tables II and III.

B. Attack Prevention and Single-Certificate Ablation

Two attacks were simulated against the running prototype. In Attack 1, a rogue gateway presented a fabricated byte sequence in place of a valid EAC/GAC signature; verification rejected it immediately at the cryptographic check (EAC/GAC Signature Invalid). In Attack 2, a legitimate gateway with valid credentials attempted to submit data for asset identifier H999, absent from its GAC; verification rejected it at the authorization layer (Asset ID Not Authorized in GAC). A baseline submission with a valid signature and an authorized asset (H088) was accepted. Both attacks were rejected in 100%

TABLE II
SINGLE-CERTIFICATE ABLATION (SAME PROTOTYPE, GAC TOGGLED)

Configuration	Attack 1	Attack 2
Single-cert (EAC only, GAC disabled)	rejected	accepted
Dual-cert (EAC + GAC)	rejected	rejected

of trials at distinct protocol layers, confirming that the two certificates enforce independent properties.

To make the necessity of the second certificate concrete rather than only argued, we ran an ablation: the same prototype with GAC verification disabled, which is precisely a single-certificate (EAC-only) system. No new infrastructure is introduced; the only change is the verification code path. Table II reports the outcome. The single-certificate configuration still blocks Attack 1 (the EAC check is unaffected) but accepts Attack 2, because with the GAC removed nothing binds the gateway to a specific asset—an attested gateway can report for any asset. The dual-certificate configuration blocks both. This ablation is the empirical counterpart of Table I: it demonstrates, within one codebase, the exact attack a single-certificate baseline cannot stop.

C. Oracle Verification Latency

Across 500 iterations, mean verification latency was 0.025 ms (P95 0.027 ms, max 0.099 ms), well within the sub-100 ms budget required for oracle-pipeline integration. Chain-link oracle nodes operate with aggregation-round deadlines of 3–30 s [2]; at 0.025 ms the dual-certificate check consumes less than 0.001% of that budget. The security overhead is therefore negligible relative to the dominant costs of network round-trips and blockchain settlement.

D. Blockchain Cost Independence

We measured gas for `updateAsset()` in two cases: a single-sensor submission (1 row, 92,061 gas) and an edge-aggregated submission derived from 11 sensor readings for the same asset (92,061 gas). The delta was 0 gas, confirming $O(1)$ on-chain cost independent of sensor density: adding sensors increases only local edge processing, while the oracle submits one aggregated record per asset per cycle regardless of how many sensors contributed.

E. End-to-End Pipeline

Processing the 33 authorized rows through the full pipeline—TPM hardware signing on the Raspberry Pi followed by `updateAsset()` submission to the Hardhat node—yielded a mean end-to-end latency of 1,171 ms (P95 1,218 ms), dominated by TPM hardware signing ($\sim 1,100$ ms); dual-certificate verification overhead is negligible relative to the settlement pipeline.

VI. CONCLUSION

RWA tokenization requires trustworthy IoT data, yet existing approaches assume trusted gateways and do not separate device execution integrity from asset authorization. We

TABLE III
PERFORMANCE EVALUATION (DUAL-CERTIFICATE PROTOTYPE)

Metric	Value
Oracle cert verification — mean	0.025 ms
Oracle cert verification — P95	0.027 ms
Oracle cert verification — max	0.099 ms
Attack 1 rejection rate	100%
Attack 2 rejection rate	100%
Gas cost — 1 sensor	92,061 gas
Gas cost — aggregated (11 sensors)	92,061 gas ($\Delta = 0$)
End-to-end pipeline — mean	1,171 ms
End-to-end pipeline — P95	1,218 ms
Dataset	500 rows, 34 IDs, 5 auth.

presented and implemented a dual-certificate architecture that separates these concerns: an EAC for gateway authentication and execution integrity, and a GAC for asset-representation rights, verified atomically by oracles. The security analysis and the single-certificate ablation together show the separation is necessary—the EAC stops unauthorized gateway deployment, while only the GAC stops asset-authorization violations. The architecture bridges Matter’s device attestation with blockchain oracle trust on commodity TPM hardware, without proprietary stacks. The prototype achieves sub-100 ms oracle verification and gas cost independent of sensor density. Future work includes a threshold-signed decentralized EAA—enabled without protocol change by our signer-agnostic certificate format—formal verification of the protocol, and zero-knowledge proofs for privacy-preserving compliance disclosure.

ACKNOWLEDGMENT

This work was supported by the IITP (Institute of Information & Communications Technology Planning & Evaluation)-ITRC (Information Technology Research Center) grant funded by the Korea government (Ministry of Science and ICT) (IITP-2026-RS-2021-II211835).

REFERENCES

- [1] BCG, “Asset tokenization: transforming financial markets,” Boston Consulting Group, 2023.
- [2] S. Breidenbach *et al.*, “Chainlink 2.0: Next steps in the evolution of decentralized oracle networks,” Chainlink Labs, White Paper, 2021.
- [3] Connectivity Standards Alliance, “Matter specification version 1.0,” CSA, Oct. 2022.
- [4] H. Zakariyya, R. A. Purwanto, and R. Wiputra, “Revitalizing the power of blockchain implementation for transaction processes in real estate sector,” in *Proc. IEEE Conf. Computer Applications (ICCA)*, Bali, Indonesia, Feb. 2025.
- [5] A. Dorri, S. S. Kanhere, R. Jurdak, and P. Gauravaram, “Blockchain for IoT security and privacy: The case study of a smart home,” in *Proc. IEEE PERCOM Workshops*, Kona, HI, USA, Mar. 2017, pp. 618–623.
- [6] O. Novo, “Blockchain meets IoT: An architecture for scalable access management in IoT,” *IEEE Internet of Things J.*, vol. 5, no. 2, pp. 1184–1195, Apr. 2018.
- [7] F. Zhang, E. Cecchetti, K. Croman, A. Juels, and E. Shi, “Town Crier: An authenticated data feed for smart contracts,” in *Proc. ACM CCS*, Vienna, Austria, Oct. 2016, pp. 270–282.
- [8] G. Caldarelli, “Understanding the blockchain oracle problem: A call for action,” *Information*, vol. 11, no. 11, p. 509, Oct. 2020.

- [9] V. Costan and S. Devadas, “Intel SGX explained,” *IACR Cryptol. ePrint Arch.*, Rep. 2016/086, 2016.
- [10] Trusted Computing Group, “TPM 2.0 library specification,” TCG, Family “2.0”, Level 00, Revision 01.59, Nov. 2019.
- [11] M. Saad *et al.*, “Exploring the attack surface of blockchain: A comprehensive survey,” *IEEE Commun. Surveys Tuts.*, vol. 22, no. 3, pp. 1977–2008, thirdquarter 2020.
- [12] Trusted Computing Group, “TCG EK credential profile for TPM family 1.2 and 2.0,” TCG Spec., Rev. 14, Nov. 2021.
- [13] P. Rajak, “Smart Home Energy Usage Dataset,” Kaggle, 2025.